

INCIDENTE LOGIN · v4 · evidencia desde Vercel logs

Owner: Celestino · 2026-05-02 · DASHBOARD_PASSWORD_SECRET **confirmado igual** en Vercel y Render por owner · login sigue fallando · Vercel logs reales obtenidos de los intentos · rama de instrumentación lista en `diag/auth-instrumentation`

Hallazgo crítico: los logs de Vercel de los 2 últimos intentos del usuario muestran *CredentialsSignin* genérico de Auth.js · **NO aparece la línea `[AUTH] recovery cross-customer ...`** que el v2 emite. Esto descarta que se haya activado Pass 2. El matcher retornó null en Pass 1 (sin ownership demostrado), o lanzó una excepción silenciosa antes de loguear. Necesitamos instrumentación para distinguir.

1. Deploy de PR #33 confirmado activo

vercel CLI tenía sesión local de *celestinojbm*. Diagnóstico read-only:

Verificación	Resultado
vercel whoami	celestinojbm · sesión activa, sin escribir nada
vercel ls dona-agent	3 deploys Production en ~40 min · todos <i><i>● Ready</i></i>
vercel inspect (deploy current)	<i>dpI_CvJgMg2T6BdojT8YfqQLTPdZR8AH</i> · target=production · status=Ready · alias <i>usadona.co</i>
Branch del deploy	main (último HEAD = a4320d4 = Merge PR #33)
Funciones deployed	<i><i>api/auth/[...nextauth]</i></i> presente · 1.05MB · region iad1
Builds	Ready · sin errores · 38s duración

Conclusión sección 1: el deploy del PR #33 está activo en producción y servido por *usadona.com*. Las hipótesis #6 ('PR #33 no desplegado') queda **descartada**.

2. Logs Vercel · 2 intentos del usuario afectado

Comando ejecutado (read-only):

```
vercel logs https://dona-agent-ilcibtq1cv-... \
--no-follow --since 1h --json -n 100
```

Líneas relevantes encontradas (cita literal redactada):

```
// Intento 1 · POST /api/auth/callback/credentials
{
  level: 'error',
  source: 'serverless',
  domain: 'www.usadona.com',
  responseStatusCode: 200,
  message: '[auth][error] CredentialsSignin: Read more at
           https://errors.authjs.dev#credentialssignin',
  logs: [
    { level: 'error', message: '[auth][error] CredentialsSignin' },
    { level: 'error', message: 'at av (.../landing_xxx_.js:404:40971)\n
      ... at async aC (...)\n
      ... at async aU (...)' },
  ],
}

// Intento 2 · POST /api/auth/callback/credentials
// (idéntico al anterior · stack trace minificado)
```

Pregunta del incidente	Respuesta basada en logs
¿Aparece <code><i>[AUTH] recovery cross-customer</i></code> en logs?	NO . Esto significa que Pass 2 nunca se activó o que el matcher lanzó excepción.
¿Hay errores de Stripe (auth, rate limit)?	NO se observan en los logs adyacentes. Pero el stack minificado podría ocultar.
¿Es null por password no match?	Posible . Es la causa más común de <code><i>CredentialsSignin</i></code> sin warns adicionales.
¿Es null por sin valid sub?	Improbable . Si fuera este caso, el password tendría que coincidir con un custom.
¿Es excepción interna?	Posible . El stack trace tiene formato <code><i>at av (...) at async aC (...)</i></code> · funciones.

3. Causa probable · ranqueada

#	Causa	Prob.	Razón
1	<code>Password no matchea ningún customer</code>	de Alta	Coherente con la ausencia del WARN. <code>DASHBOARD_PASSWORD_SECRET</code>
2	Email de <code>cus_NEW</code> difiere sutilmente · matcher <code>caseSensitive</code>	de Baja	<code><i>raw.email !== email</i></code> . Si Stripe guardó <code><i>Celestinojbm@gmail.com</i></code>
3	Sub no está en <code>active/trialing/past_due</code>	MEDIA-BAJA	Si fuera este caso Y el password matcheara, Pass 2 emitiría WARN al recuperar
4	Excepción silenciosa en <code>customers.list</code> / <code>subscriptions.list</code>	de Baja	El log de <code>stripe</code> existe pero es minificado. Posible si Stripe API throttling o aut

Veredicto provisional: el password que el usuario tipea no es un derivado válido para ninguno de los customers del email **celestinojbm@gmail.com**. Para confirmar entre causa #1 y #2 (que son distinguibles solo con instrumentación), preparé la rama **diag/auth-instrumentation**.

4. Instrumentación temporal · diag/auth-instrumentation

Branch *diag/auth-instrumentation* · **NO mergeada** · **NO desplegada**. HEAD basado en `main@a4320d4`.

Cambio en `lib/auth-matcher.ts`

```
// Nueva interfaz · solo contadores y booleanos · sin PII
export interface AuthTelemetry {
  customersCount: number;
  candidatesCount: number;
  passwordMatchedAnyCustomer: boolean;
  validSubFoundOnOwner: boolean;
  recoveryAttemptedAndFound: boolean;
  nullReason: 'no_email_or_password' | 'no_candidates'
    | 'no_password_match' | 'no_valid_sub' | null;
}

// El matcher acepta un onTelemetry opcional · si está,
// emite el objeto al terminar (incluso si retorna null).
```

Cambio en `auth.ts` · activable por env var

```
const diagOn = process.env.AUTH_DIAG === '1';
const match = await encontrarCustomerConSub(email, password, {
  customers: stripe.customers,
  subscriptions: stripe.subscriptions,
  derivePassword: deriveDashboardPassword,
  passwordMatch: constantTimeEqual,
  onTelemetry: diagOn
  ? (m) => console.warn(
    '[AUTH_DIAG] ' + JSON.stringify({...m})
  )
  : undefined,
});
```

Garantías de seguridad:

- **Default OFF**. Solo emite logs si `AUTH_DIAG=1` está seteada en Vercel.
- **Cero PII**. La telemetría tiene solo contadores y booleanos · sin email, password, customer.id ni subscription.id.
- **Test específico** verifica que el JSON serializado de la telemetría no contiene email, password ni IDs de Stripe (test 21 de los 22).
- **Reversible en 1 paso**: borrar la env var en Vercel · los logs vuelven al baseline. Eliminación final del código en otro PR cuando se confirme el diagnóstico.

5. Tests · 22/22 passing

npm test · 22 passing · vitest@2.1.9 · 311ms · 15 previos + 7 nuevos de telemetría

#	Test nuevo de telemetría	Cubre
16	Email no existe · emite customersCount=0 · nullReason='no_candidate'	Case baseline
17	Hay candidatos pero password no matchea · nullReason='no_password'	Case principal del incidente actual
18	Ownership demostrado pero ningún customer tiene sub válida · nullReason='no_valid_sub'	Case de #17
19	validSubFoundOnOwner=true cuando Pass 1 encuentra match	Happy path baseline
20	recoveryAttemptedAndFound=true cuando Pass 2 autoriza	Happy path recovery
21	Telemetría serializada NO contiene email, password, customer, onTelemetry	Test descripción
22	Sin onTelemetry el matcher funciona normal y no emite nada	Default OFF respetado

6. Validación local

Comando (cwd landing/)	Resultado
npm test	22/22 passing
npx tsc --noEmit	0 errores
rm -rf .next && npm run build	OK · 17/17 pages
npm run lint	0 errors · 3 warnings preexistentes · exit 0

7. Próxima acción mínima · espera tu OK

Plan ordenado · cada paso espera aprobación explícita.

#	Acción	Quién	Riesgo	Estado
1	Mergear <code>diag/auth-instrumentation</code> a main	Owner	Bajo · cambios cubiertos por <code>22-Test de telemetría</code>	Espera OK OFF
2	Setear <code>AUTH_DIAG=1</code> en Vercel · Production scope	Owner (Vercel UI)	Cero · solo activa logs, no to	Espera
3	Trigger redeploy o esperar autodeploy del merge	Vercel auto / Owner	Cero	Espera
4	Usuario afectado intenta login una vez	Owner coordina	Cero	Espera
5	Yo (Claude) leo los nuevos logs <code>[AUTH_DIAG] {...}</code>	Yo a vercel CLI · doy comando	Cero · solo lectura	Espera
6	Quitar <code>AUTH_DIAG</code> de Vercel + PR de cleanup que borre la instrumentación	Owner	Cero · acción temporal	Espera

8. Confirmaciones de esta sesión

NO se ejecutó:

- Stripe writes
- DB writes
- Cambios de variables de entorno (Vercel ni Render)
- Deploys manuales

- Envíos reales de WhatsApp ni email
- Stripe API queries
- Recovery manual con scripts/derive-dashboard-password.ts
- Merge a main
- *vercel redeploy* ni cualquier comando vercel que escriba en proyecto

Sí ejecuté: *vercel whoami*, *vercel ls*, *vercel inspect*, *vercel logs --no-follow*. Todos read-only · ninguno modifica el proyecto.